PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Gestion de la crise cyber

03-920 ANSSI - Crise cyber, gestion opérationnelle et stratégique, exercices et communication de crise — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La crise cyber se caractérise par une double temporalité et une menace qui s'adapte, rendant le périmètre de compromission incertain.
2. La reconstruction repose sur la mise en place d'un cœur de confiance en bulle sécurisée avec une remédiation itérative.
3. L'organisation d'un exercice sur table nécessite environ 6 semaines de préparation pour une durée de 2 à 3 heures.

La crise cyber : références et spécificités

Notion	À retenir
Guides de référence	Guide **Crise d'origine cyber** (ANSSI/**CDSE**, **décembre 2021**), guide **Exercice** (avec le **CCA**), guide **Communication** (mis à jour en **2026**, **10 fiches**).
Définition et exclusions	Évènement à **fort impact** (ex: **rançongiciel**, **déni de service**) hors fonctionnement normal. Exclut : **accidentels** et **actions malveillantes** sans interruption immédiate/majeure des services essentiels.
Spécificités cyber	Double **temporalité** (immédiat/long), **pas d'unité de lieu** (propagation), menace qui **s'adapte**, périmètre de compromission **incertain**, objectifs et origine **difficiles**.

Préparation à la crise cyber

Notion	À retenir
Connaître ses systèmes	Disposer **hors ligne** de : liste **applications/services critiques**, cartographies (systèmes, périphériques, interdépendances), politique **rétention journaux**, matrice **flux** et contacts **prestataires**.
Bâtir un socle de résilience	PCA : gérer **indisponibilité simultanée** ou activité **sans outils numériques**. PRA : reconstruction (**AD, serveurs, postes, DNS, clés**), procédures de **basculement/restauration testées**. Outils de crise **résilients**.
Communication et organisation	Préparer : stratégie, **messages types**, liste **parties prenantes**, fichier **presse hors ligne**. Dispositif : volets **stratégique/opérationnel**, cellules (métiers, com, RH, log, juridique). Modes : **alerte** et **crise**. Activation **par le haut** (volet stratégique, critères) ou **par le bas** (effet de seuil).
Assurance et entraînement	Assurance : complète la protection mais **ne couvre pas tout** et ne dispense pas de sécurité. Entraînement : stratégie **pluriannuelle** complexifiant scénarios, cellules et périmètre.

Les quatre phases de réaction

Notion	À retenir
Phase 1 : alerter, endiguer	Déclencher l'état de crise, ouvrir une **main courante**, endiguer (validation **cellule stratégique** pour blocage Internet) et éviter le **paiement de la rançon**.
Phase 2 : confiance, compréhension	Communication (plans **interne/externe**), investigation (périmètre, vecteurs, chemin d'attaque) et mise en place d'un **mode dégradé** (ex: `No More Ransom`).
Phase 3 : relancer, durcir	Reconstruction d'un **cœur de confiance** en bulle sécurisée, remédiation itérative et priorisation de **P0 à P3** selon la criticité.
Phase 4 : capitaliser	Sortie de crise (activités essentielles habituelles) et **RETEX** (capitalisation à chaud/froid) sous **30 jours** maximum après la fin.

Organisation d'un exercice de crise

Notion	À retenir
Deux formats	**Exercice sur table** (2-3 h, ~6 semaines de préparation) : 1er exercice ou direction, ne teste pas le dispositif ; **simulation** (½ à 2 jours, 2-6 mois) avec cellule d'animation.
Quatre étapes	**Concevoir** (objectifs, format) → **Préparer** (scénario, briefings) → **Dérouler** (chronogramme) → **Tirer les enseignements** (RETEX).
RANSOM20	Scénario fil rouge : attaque **EvilRansomware**, rançon sous **24 heures**, menace de publication, propagation, pression médiatique et remédiation.

Gestion de la communication de crise

Notion	À retenir
Avant la crise	Dialogue avec les **équipes cyber**, anticipation de **scénarios réalistes** (**DDoS**, **rançongiciel**, **défiguration**), constitution d'une **boîte à outils** et **entraînement**.
Pendant la crise	Organisation, **stratégie**, rédaction de **messages clés**, pilotage de la communication **interne** et **externe**. Choix de **ne pas prendre la parole immédiatement** possible.
Après la crise	Remercier les **collaborateurs**, réaliser le **RETEX**, **partager l'expérience** et **sensibiliser**.

Visibilité des attaques

> Le **rançongiciel** est très visible et paralyse souvent les outils du communicant ; l'**espionnage** est plus discret.

Pièges et confusions

- ⚠ Confondre la recherche d'un coupable avec la priorité qui est le maintien de l'activité
- ⚠ Croire qu'une crise cyber est un sprint alors que c'est une épreuve d'endurance pouvant durer des mois
- ⚠ Penser que le PCA classique suffit alors qu'il doit prévoir une activité sans aucun outil numérique
- ⚠ Oublier que les annuaires, procédures et outils de crise doivent être disponibles hors ligne
- ⚠ Considérer le paiement d'une rançon comme une option viable alors qu'il est déconseillé

Sigles et définitions

Cellule de crise stratégique	Réunit les fonctions décisionnelles pour décider, arbitrer et coordonner
Cellule de crise opérationnelle cyber et IT	Pilote l'investigation, l'endiguement, le durcissement, la remédiation et la reconstruction
Main courante	Registre chronologique des événements, décisions et actions
PCA	Plan de continuité d'activité pour maintenir les activités critiques
PRA	Plan de reprise d'activité pour organiser la reconstruction de l'infrastructure numérique
RETEX	Retour d'expérience pour la capitalisation à chaud puis à froid
Stimulus	Message simulé envoyé par l'animation pour faire évoluer la situation

Auto-test

1. Quelle est la durée maximale pour réaliser le RETEX après la fin de la crise ?
2. Qu'est-ce que l'activation par le bas ?
3. Quel document planifie minute par minute les stimuli lors d'un exercice ?
4. Quels sont les deux formats d'exercices mentionnés ?
5. Quelle est la priorité lors d'une phase de réaction ?

Réponses : **1.** 30 jours · **2.** La mobilisation du dispositif opérationnel par effet de seuil sans attendre le volet stratégique · **3.** Le chronogramme · **4.** Exercice sur table et simulation · **5.** Le maintien de l'activité

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.